

Information Security Portfolio

Coursework

Mexican government data breach

Student Full Name: Emre Ulas Inci

Student Number: T0350499

Summary

In early 2026, Mexican government systems were affected by a significant data breach resulting in the unauthorized access and exfiltration of approximately 150GB of sensitive information (Claims Journal, 2026). The compromised data reportedly included national tax records, voter registration databases, and government employee identity information. Due to the scale and sensitivity of the exposed datasets, the incident raised serious concerns regarding data protection, public trust, regulatory compliance, and national security.

The analysis conducted in this report identified that the breach was not caused by a single technical flaw, but rather by a combination of systemic weaknesses. These included insufficient authentication controls, inadequate monitoring of privileged activity, weak network segmentation, and limited oversight of outbound data transfers. The attacker was able to gain authenticated access and operate within internal systems without timely detection, allowing large-scale data extraction to occur.

A structured Information Security Management System (ISMS) has been designed in response to identified weaknesses (Whaley, 2025). The proposed ISMS clearly defines organizational scope, identifies critical information and technical assets, and applies a qualitative risk assessment methodology to prioritize key risks based on their potential business impact. The highest-risk areas relate to unauthorized access, large-scale data exfiltration, privilege escalation, regulatory penalties, and reputational damage (ENISA, 2023).

To mitigate these risks, a combination of preventative, detective, and corrective controls has been recommended. Key technical measures include the implementation of multi-factor authentication, privileged access management, network segmentation, enhanced Security Information and Event Management (SIEM), and data loss prevention mechanisms. Procedural improvements include structured access reviews, employee security awareness training, and the development of a comprehensive incident response and crisis communication plan. These measures are supported by appropriate physical

and governance controls to ensure a layered and balanced security posture (Linskens, 2025).

The financial cost of implementing these controls is significantly lower than the potential cost of a similar future breach. Regulatory penalties, operational disruption, legal consequences, and long-term reputational damage could reach millions. Investment in preventative and detective controls is therefore commercially and strategically justified.

While no security framework can eliminate risk entirely, the implementation of the proposed ISMS would significantly reduce both the likelihood and impact of similar incidents (Security-First Networking Delivers 60% Cost, 2025). It establishes a proactive, risk-based approach to information security management and strengthens organizational resilience in an evolving threat landscape.

The adoption of this ISMS would represent a substantial step toward restoring public confidence, improving regulatory compliance, and ensuring the long-term protection of critical government information assets.

1. Introduction	4
2. Incident Analysis	4
2.1 Problem Identification	4
2.2 Analysis of Attack Vectors	5
2.3 Key Assets Affected	5
2.4 Organizational Impacts	6
3. ISMS Scope	6
4. Asset Register	6
5. Identifying Threats and Vulnerabilities	7
6. Risk Assessment	8
6.1 Risk Register	8
7. Controls.....	9
7.1 Alignment with ISO/IEC 27001	10
8. Evaluation / Discussion	11
9. Conclusion	12

1. Introduction

In early 2026, reports emerged of a large-scale data breach affecting Mexican government systems. Sensitive data were allegedly accessed and exfiltrated by a threat of actors. The compromised information reportedly included tax records, voter registration databases, and identity information of government employees. Due to the nature of the exposed datasets, the incident raised serious concerns regarding data protection, public trust, and national security.

This report provides a structured analysis of the incident and develops a tailored Information Security Management System (ISMS) designed to mitigate similar threats in the future. The first section critically examines the attack vectors, key assets affected, and organisational impacts. The second section defines the scope of the proposed ISMS, identifies critical assets, conducts a structured risk assessment, and proposes appropriate security controls. The report concludes by evaluating how the ISMS addresses the weaknesses revealed by the breach.

2. Incident Analysis

2.1 Problem Identification

Unauthorized access to multiple databases and the exfiltration of approximately 150GB of sensitive information. Public reports identify exposed datasets including tax records, voter rolls, and government employee identity data. Available evidence indicates that the attacker achieved authenticated access to internal systems and operated without immediate detection for an extended period. The incident therefore reflects systemic failures rather than a single isolated flaw: weaknesses existed in identity and access management, monitoring and logging, and controls over outbound data transfers. In short, the organization lacked a sufficiently mature, risk-based security management approach, which allowed initial access to escalate to large-scale data extraction before containment.

2.2 Analysis of Attack Vectors

The breach appears to have followed a multi-stage pattern: automated reconnaissance, credential compromise, lateral movement using valid accounts, and large-scale exfiltration enabled by insufficient monitoring and weak egress controls.

Based on publicly reported information, the breach appears to have been conducted through a multi-stage attack combining social engineering, credential compromise, and large-scale data exfiltration. While full forensic details remain undisclosed, the sequence of events suggests the following primary attack vectors.

The initial stage likely involved reconnaissance activities targeting publicly exposed services and user accounts associated with government systems. The attacker reportedly used automated techniques to identify vulnerable access points and potential authentication weaknesses.

The second stage appears to have involved credential compromise. This may have been achieved through phishing campaigns, password reuse exploitation, or abuse of insufficient multi-factor authentication controls. Once valid credentials were obtained, the attacker was able to authenticate as a legitimate user, significantly reducing the likelihood of immediate detection.

Following initial access, lateral movement within internal systems was likely performed using valid accounts. Weak network segmentation and insufficient privileged access management may have allowed escalation of access rights beyond the originally compromised account.

The final stage involved the exfiltration of approximately 150GB of sensitive data. The scale of the data extraction suggests inadequate outbound traffic monitoring, limited data loss prevention (DLP) mechanisms, and insufficient anomaly detection controls.

Overall, the attack did not rely on a single sophisticated vulnerability. Instead, it appears to have exploited a combination of governance weaknesses, insufficient access controls, and limited monitoring capabilities.

2.3 Key Assets Affected

The breach primarily affected high-value government information assets. These assets can be categorized into information assets, technical assets, and organizational assets (Law, 2024). The most critical impacted information assets included national tax records, voter registration databases, and government employee identity information. These datasets

contain personally identifiable information (PII), financial data, and potentially politically sensitive information (Protected, 2024).

Technical assets involved in the breach likely include authentication systems, database servers, application servers, API gateways, and cloud storage environments. Compromise of these systems enabled data access and extraction.

Organizational assets were also affected, including public trust, institutional credibility, and regulatory compliance status. Although intangible, these assets carry significant strategic value and long-term impact.

Given the sensitivity of government-held citizen data, these assets must be classified as highly confidential and critical to national operations.

2.4 Organizational Impacts

The short-term impact of the breach included immediate incident response costs, forensic investigation requirements, and potential operational disruption. Emergency mitigation actions such as credential resets, access reviews, and system audits would require substantial technical and financial resources.

The exposure of citizen data also created immediate privacy risks, including identity theft, fraud, and targeted phishing attacks against affected individuals.

Medium-term impacts include regulatory scrutiny, potential legal consequences, and reputational damage. Loss of public trust in government data protection capabilities can have long-lasting implications, particularly where voter registration data are involved. Furthermore, the incident highlights systemic weaknesses in governance and risk management, potentially requiring structural reforms, policy redesign, and long-term security investment.

3. ISMS Scope

The scope covers the government information systems responsible for storing and processing sensitive citizen data. This includes tax record databases, voter registration systems, government employee identity records, authentication systems, supporting network infrastructure, and associated cloud environments.

Systems and departments that do not process sensitive citizen information are excluded. Physical security controls are considered only at a general policy level.

4. Asset Register

The following asset register identifies the critical assets within the defined ISMS scope.

Asset ID	Asset Name	Asset Type	Owner	Confidentiality	Integrity	Value
A1	National Tax Records Database	Information	Ministry of Finance	High	High	High
A2	Voter Registration Database	Information	Electoral Authority	High	High	High
A3	Government Employee Identity Records	Information	HR Department	High	High	Medium
A4	Citizen Personal Data (PII)	Information	Data Protection Office	High	High	High
A5	Authentication System (IdP)	Software	IT Department	High	High	High
A6	Privileged Access Management System	Software	IT Security	High	High	High
A7	Database Servers	Hardware	IT Operations	Medium	High	High
A8	Application Servers	Hardware	IT Operations	Medium	High	High
A9	Cloud Storage Platform	Software	IT Infrastructure	High	High	High
A10	API Gateway	Network	IT Security	Medium	High	High
A11	Internal Network Infrastructure	Network	IT Operations	Medium	High	High

A12	Security Monitoring (SIEM)	Software	IT Security	High	High	High
A13	Backup Systems	Hardware	IT Operations	High	High	High
A14	System Administrators	People	IT Department	High	High	Medium
A15	Public Trust & Reputation	Service	Government Leadership	High	High	Medium

5. Identifying Threats and Vulnerabilities

A threat agent is an individual or entity that attempts to exploit weaknesses within a system to cause harm or gain unauthorized access. In the context of the analyzed incident, threat agents may include external attackers, malicious insiders, or opportunistic cybercriminal groups.

A vulnerability refers to a weakness in a system, process, or control that can be exploited by a threat agent (Kapon, 2025). The breach affecting Mexican government systems demonstrates that multiple vulnerabilities existed across technical and procedural layers.

External attackers (hackers) may exploit vulnerabilities such as weak authentication mechanisms, excessive database permissions, outdated software, insufficient network segmentation, and non-encrypted data storage. These weaknesses can result in threats including unauthorized system access, data exfiltration, modification of sensitive records, and deployment of malicious software.

Employees may unintentionally act as threat vectors due to limited security awareness, weak password practices, or susceptibility to phishing attacks. Human error can result in compromised credentials, accidental disclosure of data, or improper configuration of access controls.

Insider threats represent an additional risk, particularly where privileged users already possess authorized system access. In the absence of adequate auditing and behavioral monitoring, malicious insiders may manipulate data, leak confidential information, or misuse administrative privileges without detection.

Malware-related threats may arise where systems lack effective anti-malware protection, vulnerability scanning, or patch management processes. Outdated software increases

exposure to exploitation techniques that may enable remote access or unauthorised control of systems.

Overall, the identified threats are directly linked to vulnerabilities in authentication, monitoring, governance, and access management. These relationships provide the foundation for risk assessment and subsequent control selection.

6. Risk Assessment

The risk assessment in this report follows a qualitative approach aligned with the principles outlined in ISO/IEC 27005. The process involves four key stages: risk identification, risk analysis, risk evaluation, and risk treatment (ISO, 2018).

6.1 Risk Register

No.	Risk	Asset ID	Vulnerability	Likelihood	Impact	Action	Plan	Cost if Risk Occurs
R1	Unauthorised access to government systems	A1, A2, A5, A6	Weak authentication mechanisms and limited monitoring of login attempts may allow attackers to gain access using compromised credentials.	High	Very High	Disable compromised accounts and review system logs to determine the extent of access.	Implement strong multi-factor authentication and enforce strict password policies with continuous monitoring.	£0 – £3 million+
R2	Large-scale data breach	A1, A2, A4, A9	Insufficient data access restrictions and lack of outbound traffic monitoring may enable mass data extraction.	High	Very High	Identify affected datasets and notify relevant authorities and individuals as required.	Deploy Data Loss Prevention (DLP) tools and apply role-based access control (RBAC).	£0 – £5 million+
R3	Privilege escalation	A5, A6, A14	Excessive user privileges and absence of strict privileged access management controls.	Medium	Very High	Suspend privileged sessions and conduct a full access rights review.	Introduce Privileged Access Management (PAM) and apply the principle of least privilege.	£1 – £2 million
R4	Insider misuse of sensitive data	A1, A2, A14	Limited oversight of privileged users and absence of behavioural monitoring systems.	Medium	High	Investigate suspicious internal activities and restrict access where necessary.	Implement user activity monitoring and conduct periodic internal audits.	£500,000+
R5	Failure to detect cyber intrusion	A12, A11	Weak log analysis processes and insufficient SIEM configuration delay identification of malicious activity.	High	High	Conduct forensic investigation and strengthen monitoring capabilities.	Enhance log correlation rules and implement continuous security monitoring.	£1 million+
R6	Loss of public trust	A15, A1, A2	Inadequate incident communication strategy and delayed transparency.	Medium	Very High	Issue official public communication and provide guidance to affected citizens.	Develop formal crisis communication and incident response communication plans.	£2 – £10 million (long-term impact)
R7	Data integrity compromise	A1, A13	Inadequate encryption and lack of verified backup procedures.	Medium	High	Restore systems using latest verified backups and validate data integrity.	Encrypt sensitive data and implement a structured backup schedule with regular testing.	£500,000+
R8	Regulatory penalties and legal consequences	A1, A2, A4	Non-compliance with data protection regulations and insufficient governance oversight.	Medium	Very High	Cooperate with regulatory authorities and conduct compliance audit.	Establish formal compliance monitoring and periodic risk assessments.	£1 – £5 million+
R9	Lateral movement within internal network	A7, A8, A11	Poor internal network segmentation and insufficient access restrictions.	Medium	High	Isolate affected network segments and analyse internal traffic logs.	Implement network segmentation and adopt zero-trust access principles.	£750,000+
R10	Service disruption and operational downtime	A7, A8, A11	Inadequate disaster recovery testing and lack of resilience planning.	Medium	High	Activate business continuity procedures and restore affected services.	Develop and regularly test disaster recovery and business continuity plans.	£5,000 per hour of downtime

7. Controls

The following controls are recommended to mitigate the risks identified in the previous section (Murphy, 2025). Each control is categorized as preventative, detective, or corrective, and further classified as technical, procedural, or physical.

Preventative controls aim to reduce the likelihood of an incident occurring (Arch, 2020). Detective controls identify suspicious activity or vulnerabilities. Corrective controls are implemented after an incident to minimize impact and restore normal operations (Bevin, 2025).

The proposed controls focus on strengthening authentication, monitoring, data protection, governance, and resilience mechanisms within the defined ISMS scope.

Control	Type of Control	Category	Explanation	Estimated Cost of Implementation
Multi-Factor Authentication (MFA)	Preventative	Technical	Adds an additional authentication layer beyond username and password, reducing risk of credential compromise. Recommended implementation includes phishing-resistant authentication methods.	£5,000 per annum
Privileged Access Management (PAM)	Preventative	Technical	Controls and monitors privileged accounts, limiting administrative access and recording sessions to prevent misuse or escalation.	£15,000 per annum
Role-Based Access Control (RBAC)	Preventative	Procedural	Ensures access to sensitive data is granted only on a need-to-know basis according to defined job roles.	£3,000 (implementation and configuration)
Data Loss Prevention (DLP)	Detective	Technical	Monitors and restricts large or suspicious data transfers to prevent mass data exfiltration.	£12,000 per annum
Security Information and Event Management (SIEM) Enhancement	Detective	Technical	Improves log correlation and real-time monitoring to detect anomalous behaviour across systems.	£10,000 per annum
Network Segmentation	Preventative	Technical	Divides internal networks into isolated segments to prevent lateral movement during an intrusion.	£20,000 (infrastructure update)
Encryption of Data at Rest and in Transit	Preventative	Technical	Protects sensitive data through encryption mechanisms to maintain confidentiality even if systems are compromised.	£8,000 per annum
Backup and Disaster Recovery Plan	Corrective	Procedural	Establishes structured backup schedule and recovery testing to ensure availability of systems in case of failure.	£5,000 per annum
Incident Response Plan	Corrective	Procedural	Defines clear procedures for detecting, responding to, and recovering from security incidents, including communication strategy.	£20,000 (development and training)
Security Awareness Training	Preventative	Procedural	Educates employees on phishing, credential protection, and secure practices to reduce human error risks.	£3,000 per training cycle
Vulnerability Scanning	Detective	Technical	Regular automated scanning to identify system weaknesses before they can be exploited.	£4,000 per annum
Firewall and Network Traffic Filtering	Preventative	Technical	Restricts unauthorised inbound and outbound network traffic to reduce exposure to malicious activity.	£10,000 per annum
Access Control System (Server Rooms)	Preventative	Physical	Restricts physical access to critical hardware through biometric or card-based authentication.	£7,000 initial installation

7.1 Alignment with ISO/IEC 27001

Controls align with internationally recognized information security standards, particularly ISO/IEC 27001 Annex A (Bendoraitis, 2026).

The implementation of multi-factor authentication and privileged access management supports Annex A.9 (Access Control), specifically controls relating to secure log-on procedures and the management of privileged access rights.

Enhanced logging, monitoring, and SIEM configuration align with Annex A.12.4 (Logging and Monitoring), which requires event logging and monitoring of system activities to detect unauthorized access and anomalies.

The implementation of data encryption mechanisms corresponds to Annex A (A Guide to Data Encryption Laws, 2024). 10 (Cryptographic Controls), ensuring the protection of sensitive information both at rest and in transit.

Network segmentation and firewall configurations align with Annex A.13 (Communications Security), which addresses the protection of information in networks and supporting infrastructure.

Backup procedures and disaster recovery planning are consistent with Annex A.12.3 (Information Backup) and Annex A.17 (Information Security Aspects of Business Continuity Management), ensuring system resilience and availability (Edwards, 2025).

Security awareness training and incident response planning align with Annex A.7 (Human Resource Security) and Annex A.16 (Information Security Incident Management), reinforcing procedural and organizational security measures.

By aligning the proposed controls with ISO/IEC 27001, the ISMS demonstrates adherence to recognized best practices and strengthens governance, compliance, and accountability within the organization.

8. Evaluation / Discussion

After reviewing this breach, it is evident that the incident could have been significantly reduced, or potentially prevented, if stronger technical and procedural controls had been implemented. The most critical weaknesses were related to authentication, access management, and monitoring. These are fundamental security controls, and their absence created an environment in which attackers were able to operate without immediate detection.

The risks associated with unauthorized access and large-scale data exfiltration carry the highest financial and reputational cost. As outlined in the risk assessment, the cost of implementing preventative controls such as multi-factor authentication, privileged access management, and data loss prevention systems is considerably lower than the potential cost of a large-scale breach. When sensitive citizen data are involved, regulatory penalties, legal claims, and long-term reputational damage can reach millions (ICO, 2023). The financial justification for implementing these controls is therefore clear.

Improved monitoring mechanisms could have detected suspicious login behaviour or abnormal data transfers earlier. With effective SIEM configuration, intrusion detection, and regular vulnerability scanning, the attacker activity may have been identified before large volumes of data were extracted. This highlights the importance of detective controls in addition to preventative measures.

Procedural controls are equally important. A structured incident response plan and communication strategy would reduce confusion during a crisis and help maintain public trust. In government environments, transparency and timely communication are essential. Without a defined response framework, reputational damage increases significantly.

Physical and organizational controls also contribute to overall resilience. While the primary breach involved logical access, physical access restrictions and governance oversight ensure that security is managed holistically rather than in isolated silos.

Although the proposed ISMS cannot guarantee that no future attack will occur, it creates a significantly stronger security posture. By combining preventative, detective, and corrective controls, the organisation reduces the likelihood of similar incidents and improves its ability to respond effectively if they do occur. The overall investment required for these improvements is justified when compared to the cost of potential regulatory fines, operational disruption, and long-term loss of public confidence.

9. Conclusion

The 2026 data breach affecting Mexican government systems demonstrates the serious consequences of insufficient access control, weak monitoring, and inadequate governance. The exposure of sensitive tax records, voter data, and employee information had wide-ranging implications for citizens, regulatory compliance, and public trust.

The analysis conducted in this report identified critical assets, examined associated threats and vulnerabilities, and evaluated the risks in business terms. Based on this

assessment, a structured Information Security Management System (ISMS) was proposed to address the weaknesses revealed by the incident.

The recommended controls — including multi-factor authentication, privileged access management, data loss prevention, enhanced monitoring, structured backup processes, and formal incident response planning — provide a layered approach to security. Together, these measures strengthen confidentiality, integrity, and availability across the organization.

While no system can eliminate risk entirely, the adoption of a structured and continuously reviewed ISMS would significantly reduce the likelihood and impact of similar breaches in the future. More importantly, it demonstrates a commitment to proactive security management rather than reactive response.

In environments where large volumes of sensitive public data are processed, strong information security governance is essential. The implementation of this ISMS would improve organisational resilience, support regulatory compliance, and contribute to restoring and maintaining public trust.

References

Kapon, B. (2025, March 19). Vulnerability vs. Threat vs. Risk: Key Differences. Kelacyber. Available at: <https://www.kelacyber.com/academy/cti/vulnerability-vs-threat-vs-risk-key-differences/> (Retrieved at: 1st March 2026)

Bevin, L. (2025, January 17). What are the Three Internal Controls? ZenGRC. Available at: <https://www.zengrc.com/blog/what-are-the-three-internal-controls/> (Retrieved at: 28th February 2026)

Law, W. (2024, September 23). Protecting your business assets: Key principles of General Business Law. WeisbergLawOffices. Available at: <https://www.weisberglawoffices.com/blog/2024/october/protecting-your-business-assets-key-principles-o/> (Retrieved at: 28th February 2026)

Protected, P. (2024, December 18). Data security in the Digital Age: How IDCerberus Protects Sensitive information. idCerberus. Available at: <https://idcerberus.com/data-security-in-the-digital-age-how-idcerberus-protects-sensitive-information/> (Retrieved at: 28th February 2026)

A guide to data encryption Laws. (2024, February 22). Secure IT World.

Available at: <https://www.secureitworld.com/article/data-encryption-laws-a-comprehensive-guide-to-compliance/> (Retrieved at: 1st March 2026)

Edwards, H. (2025, August 13). ISO 27001 controls: What is Annex A:17? | Citation Group. Citation Group. Available at: <https://citationgroup.com.au/resources/iso-27001-controls-what-is-annex-a17/> (Retrieved at: 28th February 2026)

Whaley, G. (2025, July 4). The structure of an IT security management system. Keystone Technology Consultants. Available at: <https://keystonecorp.com/cybersecurity/the-structure-of-an-it-security-management-system/> (Retrieved at: 1st March 2026)

Arch. (2020). Hazard Logs #4 - The Importance of Effective Controls.

Available at: <https://www.archservices.com.au/articles/hazard-logs-4---the-importance-of-effective-controls> (Retrieved at: 28th February 2026)

Security-First networking delivers 60% cost. . . (2025, October 20). INE. Available at: <https://ine.com/newsroom/security-first-networking-delivers-60-cost-savings-new-analysis-reveals> (Retrieved at: 2nd March 2026)

Linskens, A. (2025, October 23). The True Cost of Not Having a Cloud Repository. Sona type. Available at: <https://www.sonatype.com/blog/the-true-cost-of-not-having-a-cloud-repository> Retrieved at: (2nd March 2026)

Murphy, L. (2025, December 9). End-to-End ISO 27001 Guide: Everything You Need to Know About Requirements, Controls, Costs & Certification. Hicomply. Available at: <https://www.hicomply.com/en-us/iso-27001> (Retrieved at: 4th March 2026)

ENISA (2023) ENISA Threat Landscape 2023. European Union Agency for Cybersecurity. Available at: <https://www.enisa.europa.eu> (Retrieved at: 1st March 2026).

ICO (2023) Data protection and enforcement trends report. Information Commissioner's Office. Available at: <https://ico.org.uk> (Retrieved at: 5th March 2026).

NIST (2012) Guide for Conducting Risk Assessments (SP 800-30 Rev. 1). National Institute of Standards and Technology. Available at: <https://csrc.nist.gov> (Retrieved at: 28th February).

Verizon (2023) Data Breach Investigations Report (DBIR). Verizon Enterprise. Available at: <https://www.verizon.com/business/resources/reports/dbir/> (Accessed: 28th February 2026).

Ponemon Institute (2023) Cost of a Data Breach Report. IBM Security. Available at: <https://www.ibm.com/security/data-breach> (Accessed: 2nd March 2026).

Claims Journal., (2026, February 25). Hacker Used Anthropic's Claude to Steal Sensitive Mexican Data. Available at: <https://www.claimsjournal.com/news/national/2026/02/25/335916.htm> (Retrieved at: 27th February)

Bendoraitis, N., (2026, January 23). ISO 27001 controls list: Full Annex A guide - Copla. Available at: <https://copla.com/blog/compliance-regulations/iso-27001-controls-list-a-complete-guide-to-annex-a-and-control-objectives/> (Retrieved at: 1st March)